

14-Containers - DoorDasher's Demise

Introduction



Parecía que al amanecer de esta mañana ya se había decidido que hoy sería otro día de caos en Wareville. Al menos esa era la sensación que tenían todos en "DoorDasher". DoorDasher es el servicio de reparto de comida local de Wareville, uno de los favoritos de los trabajadores de The Best Festival Company, sobre todo en los días largos, cuando llegan a casa del trabajo y no se animan a preparar la cena. Seguro que a todos nos ha pasado.

Bueno, un residente de Wareville se sentía particularmente cansado esta mañana y decidió pedir el desayuno. Solo para descubrir que el Rey Malhare y sus batallones de conejos bandidos se habían apoderado de otro de los platos favoritos de las fiestas. DoorDasher había cambiado completamente su nombre a Hopperoo. Todos los platos favoritos de la zona también habían cambiado. Los informes empezaron a llegar al centro de llamadas de DoorDasher. Y no solo de los clientes. La organización de salud y seguridad alimentaria también estaba al teléfono, presa del pánico. Al parecer, varios residentes de Wareville se estaban atragantando con lo que resultaron ser fragmentos de la barba de Papá Noel. Las autoridades de Wareville quedaron sumidas en la confusión hoy, mientras Hopperoo enfrentaba una creciente reacción negativa por los informes de "suplantación culinaria". Clientes de toda la región afirman haber recibido lo que parecen ser auténticos mechones de la barba de Papá Noel en lugar de los tradicionales fideos.

Un portavoz de la Oficina de Salud y Seguridad Alimentaria confirmó que varios comensales tuvieron que ser desenredados con cuidado y que, en un incidente, un cliente "logró sincronizar accidentalmente su vello facial".



Inmediatamente, uno de los ingenieros de seguridad logró iniciar sesión y crear un script que restauraría DoorDasher a su estado original, pero justo antes de que pudiera ejecutarlo, Sir CarrotBaine se enteró de su intento y lo bloqueó del sistema. Todo estaba perdido, hasta que el equipo del SOC se dio cuenta de que aún tenían acceso al sistema a través de su módulo de monitoreo, un verificador de disponibilidad del sitio. ¿Tu trabajo? Como miembro del equipo del SOC de DoorDasher, ¿puedes escapar del contenedor y escalar tus privilegios para terminar lo que tu equipo comenzó y salvar el sitio?

Objetivos de aprendizaje

Aprender cómo funcionan los contenedores y Docker, incluyendo imágenes, capas y el motor de contenedores.

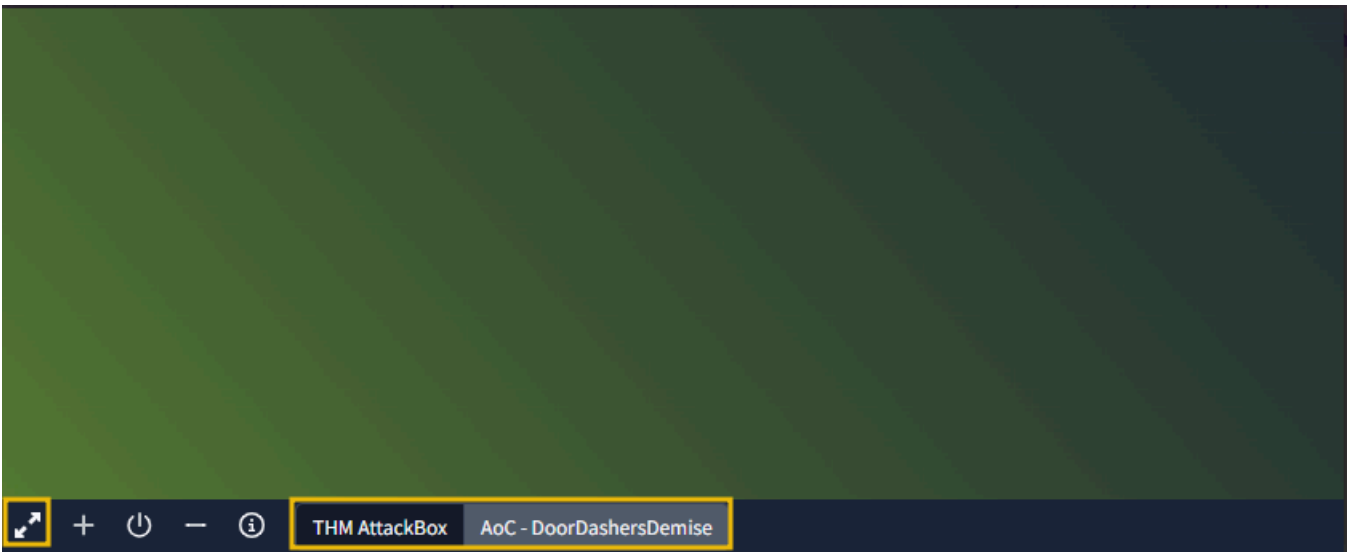
Explorar los conceptos de tiempo de ejecución de Docker (sockets, API de daemon) y los vectores comunes de escape/escalada de privilegios de contenedores.

Aplicar estas habilidades para investigar capas de imágenes, escapar de un contenedor, escalar privilegios y restaurar el servicio DoorDasher.

NO pedir "Santa's Beard Pasta".

Inicie el laboratorio haciendo clic en el botón "Iniciar máquina" a continuación. La máquina se iniciará en vista dividida y tardará unos dos minutos en cargarse. Si la máquina no está visible, haga clic en el botón "Mostrar vista dividida" en la parte superior de la página. Una vez cargada, debería tener acceso al usuario mrbombastic. Recibirá comandos para ejecutar esta máquina virtual en la siguiente tarea. Además, inicie AttackBox pulsando "Iniciar AttackBox" a continuación.

Nota: Se recomienda abrir ambas máquinas en pantalla completa usando el pequeño ícono en el extremo izquierdo de la captura de pantalla a continuación; de lo contrario, podría salir del contenedor Docker al cambiar de pestaña en la vista dividida. Si aún prefiere usar la vista dividida, puede cambiar entre la máquina de destino y AttackBox usando las pestañas inferiores, como se muestra a continuación:



Answer the questions below

Tell me more!

No answer needed

Container Security

¿Qué son los contenedores?

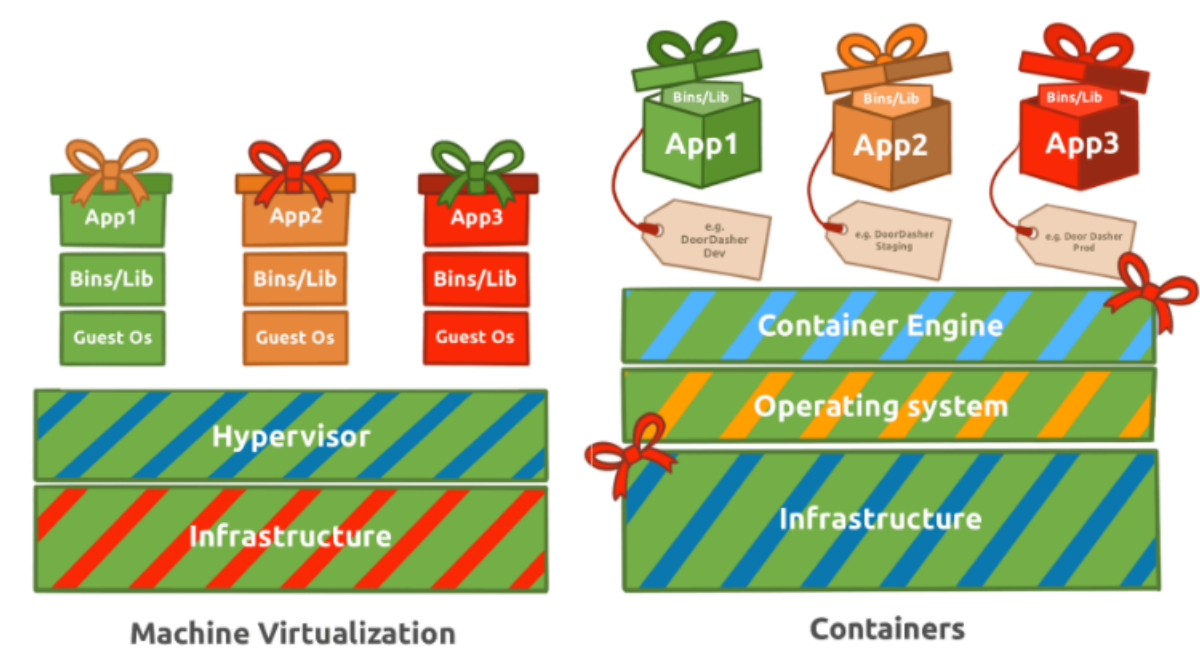
Para entender qué es un contenedor, primero debemos comprender el problema que soluciona. En resumen, las aplicaciones modernas pueden ser bastante complejas:

- Instalación:** Dependiendo del entorno en el que se instale la aplicación, es frecuente encontrar problemas de configuración que hacen que el proceso sea lento y frustrante.
- Solución de problemas:** Cuando una aplicación deja de funcionar, se puede perder mucho tiempo determinando si se trata de un problema de la propia aplicación o del entorno en el que se ejecuta.
- Conflictos:** A veces es necesario ejecutar varias versiones de una aplicación, o quizás varias aplicaciones que requieren (por ejemplo) la instalación de diferentes versiones de Python. Esto puede generar conflictos, complicando aún más el proceso.

Si al leer estos problemas se te ocurrió la palabra "aislamiento" como solución, estás en el camino correcto. La contenedorización resuelve estos problemas empaquetando las aplicaciones, junto con sus dependencias, en un entorno aislado. Este paquete se conoce como contenedor. Además de resolver todos los problemas mencionados, la contenedorización también ofrece otras ventajas. Una de ellas es su ligereza. Para comprender esto, analizaremos brevemente la arquitectura de contenedores.

Contenedores vs. Máquinas Virtuales

Para ilustrar la arquitectura de contenedores, examinemos otra forma de virtualización: las Máquinas Virtuales. Máquinas virtuales, como las que han estado ejecutando en esta plataforma durante Advent of Cyber.



Una máquina virtual se ejecuta en un hipervisor (software que emula y administra múltiples sistemas operativos en un host físico). Incluye un sistema operativo huésped completo, lo que la hace más pesada, pero completamente aislada. Los contenedores comparten el kernel del sistema operativo host, aislando únicamente las aplicaciones y sus dependencias, lo que los hace ligeros y rápidos de iniciar. Las máquinas virtuales son ideales para ejecutar múltiples sistemas operativos o aplicaciones heredadas, mientras que los contenedores destacan en la implementación de microservicios escalables y portátiles.

Aplicaciones a Escala

Los microservicios suponen un cambio en el estilo de arquitectura de aplicaciones. Antes era mucho más común implementar aplicaciones de forma monolítica (construidas como una sola unidad, una única base de código, generalmente como un único ejecutable). Cada vez más empresas optan por dividir sus aplicaciones en partes según su función empresarial. De esta forma, si una parte específica de su aplicación recibe mucha carga de tráfico, pueden escalarla sin tener que escalar toda la aplicación. Aquí es donde entra en juego la ligereza de los contenedores, lo que facilita enormemente su escalabilidad para satisfacer las crecientes demandas. Se convirtieron en la opción predilecta para esta arquitectura (cada vez más popular), y por eso, en los últimos 10 años, el término se ha vuelto cada vez más común.

Quizás haya notado una capa denominada "Motor de Contenedores" en el diagrama. Un motor de contenedores es un software que crea, ejecuta y administra contenedores aprovechando las características del kernel del sistema operativo del host, como los espacios de nombres y los cgroups. Un ejemplo de motor de contenedores es Docker, que examinaremos con más detalle. Docker es un popular motor de contenedores que utiliza Dockerfiles, scripts de texto simples que definen entornos y dependencias de aplicaciones, para crear, empaquetar y ejecutar aplicaciones de forma coherente en diferentes sistemas. Docker es el motor de contenedores predilecto en "DoorDasher" y, por lo tanto, es con lo que interactuaremos en nuestro laboratorio interactivo.

Docker

Docker es una plataforma de código abierto para que los desarrolladores creen, implementen y administren contenedores. Los contenedores son unidades ejecutables de software que empaquetan y administran el software y los componentes para ejecutar un servicio. Son bastante livianos porque aíslan la aplicación y utilizan el kernel del sistema operativo host.



Ataque de Escape y Sockets

Un escape de contenedor es una técnica que permite que el código que se ejecuta dentro de un contenedor obtenga permisos o se ejecute en el kernel del host (u otros contenedores) más allá de su entorno aislado (escape). Por ejemplo, se crea un contenedor privilegiado con acceso a internet público desde un contenedor de prueba sin acceso a internet.

Los contenedores utilizan una configuración cliente-servidor en el host. Las herramientas CLI actúan como cliente, enviando solicitudes al demonio del contenedor, que gestiona la gestión y ejecución del contenedor. El entorno de ejecución expone un servidor API mediante sockets Unix (sockets de tiempo de ejecución) para gestionar el tráfico de CLI y del demonio. Si un atacante puede comunicarse con ese socket desde el interior del contenedor, puede explotar el entorno de ejecución (así es como crearíamos el contenedor privilegiado con acceso a internet, como se mencionó en el ejemplo anterior).

Desafío

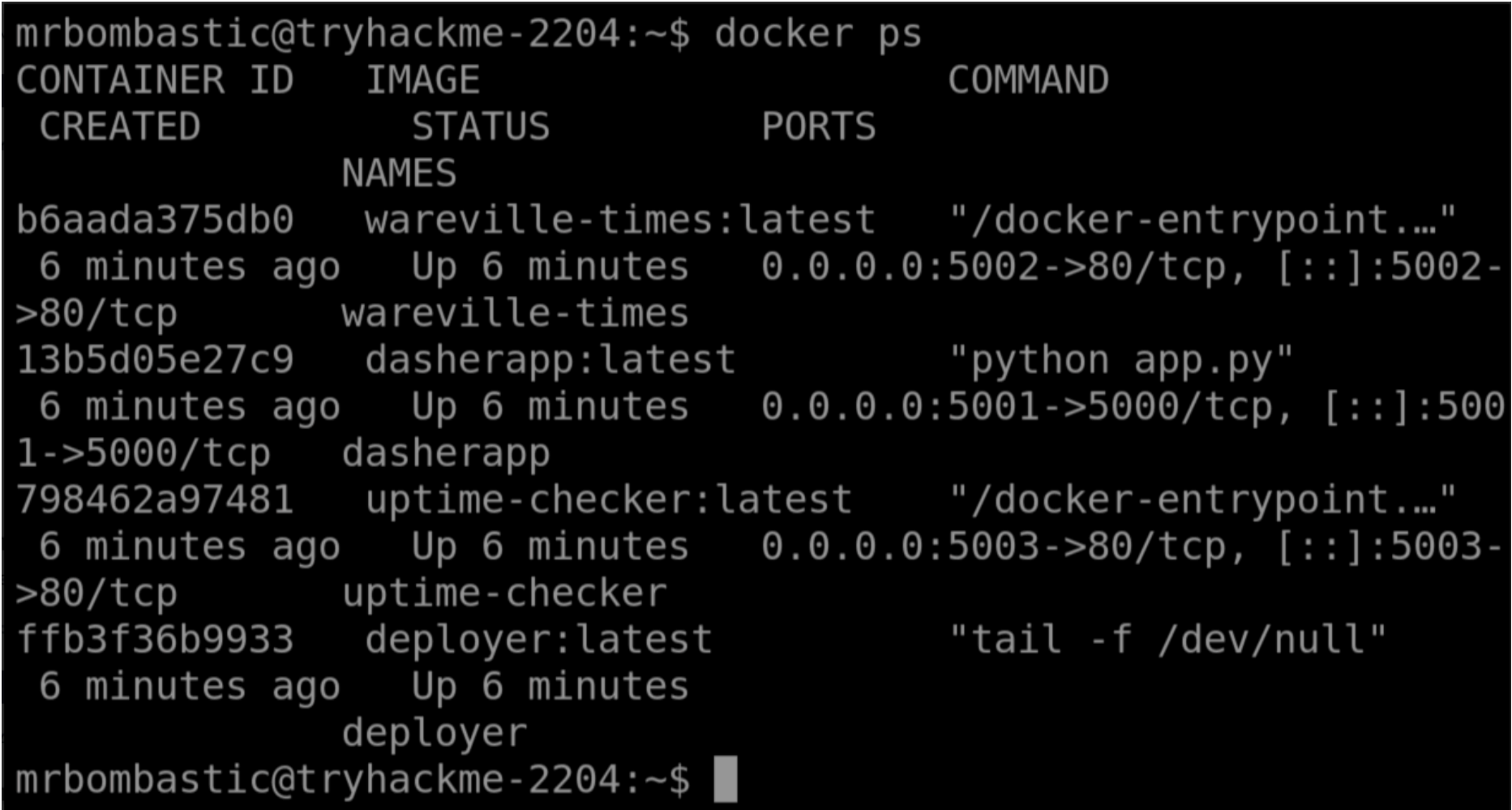
Tu objetivo es investigar las capas de Docker y restaurar el sitio web alterado de Hopperoo a su servicio original: DoorDasher. ¡Repasaremos los pasos para superar este desafío juntos!

Puntos de acceso

Ahora es el momento de empezar a usar la máquina que iniciaste en la tarea 1. Comprobemos qué servicios se están ejecutando con Docker. Ejecuta el siguiente comando:

```
docker ps
```

Debería ver algunos servicios ejecutándose:



El servicio principal se ejecuta en `http://MACHINE_IP:5001`. Explore la aplicación web y observe el sistema modificado "Hopperoo". Sabemos que DoorDasher es un servicio de entrega de comida. exploremos el comprobador `uptime-checker` . Suena interesante.

Ejecute el siguiente comando para acceder al contenedor `uptime-checker` :

```
docker exec -it uptime-checker sh
```

Después de iniciar sesión, verifique el acceso al socket ejecutando: `ls -la /var/run/docker.sock`

La documentación de Docker menciona que, por defecto, existe una configuración llamada "Aislamiento mejorado de contenedores" que impide que los contenedores monten el socket de Docker para evitar accesos maliciosos al motor de Docker. En algunos casos, como al ejecutar contenedores de prueba,

necesitan acceso al socket de Docker. El socket proporciona un medio para acceder a los contenedores directamente a través de la API. Veamos si podemos. El resultado debería ser algo como esto:

```

mrbombastic@tryhackme-2204:~$ docker exec -it uptime-checker sh
/ # ls -la /var/run/docker.sock
srw-rw---- 1 root 121 0 Oct 22 21:26 /var/run/docker.sock
/ # █

```

Me pregunto qué pasa si intentamos ejecutar comandos de Docker dentro del contenedor. Al ejecutar `docker ps` de nuevo, podemos confirmar que podemos ejecutar comandos de Docker e interactuar con la API; en otras palabras, ¡podemos realizar un ataque de escape de Docker!

En su lugar, intentemos acceder al contenedor `deployer`, que es un contenedor privilegiado. Ejecute el siguiente comando:

```
docker exec -it deployer bash
```

Escriba `whoami` y compruebe con qué usuario hemos iniciado sesión. Explore el contenedor y encuentre la bandera.

¡Listo, lo logramos! ¡Hemos llegado al contenedor donde se encuentra el script para restaurar el sitio a su versión anterior! Para solucionarlo, ejecute el `recovery_script` en el directorio raíz para recuperar la aplicación usando `sudo`:

```
sudo /recovery_script.sh
```

Con esa ejecución, podrá comprobarlo usted mismo actualizando el sitio (http://MACHINE_IP:5001). Como recompensa, debería encontrar una bandera en el mismo directorio que el script (/), que puede leer con el comando `cat` .

Answer the questions below

What exact command lists running Docker containers?

Respuesta: docker ps

What file is used to define the instructions for building a Docker image?

Respuesta: Dockerfile

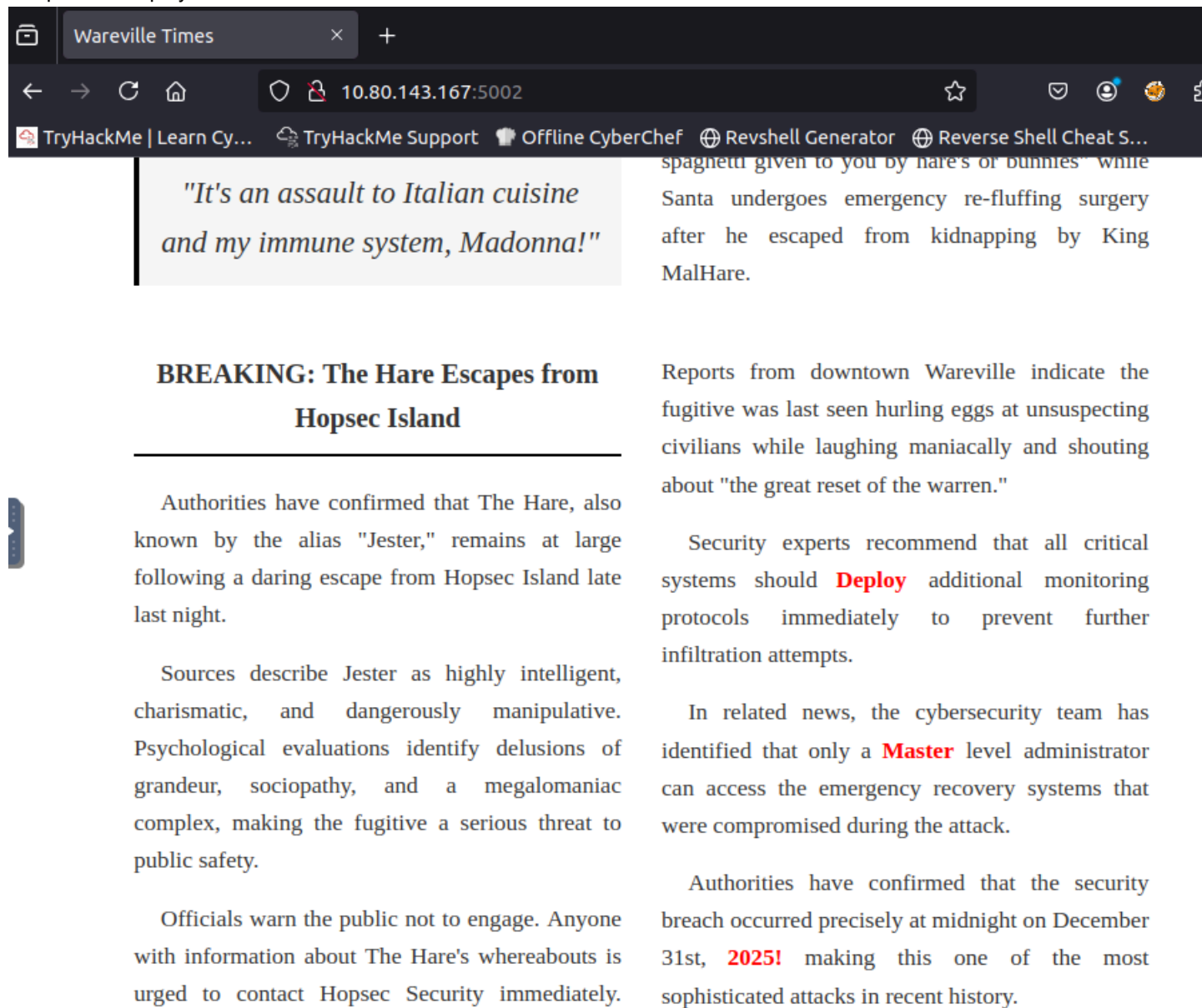
What's the flag?

Respuesta: THM{DOCKER_ESCAPE_SUCCESS}

```
/ # docker exec -it deployer bash
deployer@30bf6f140697:/app$ cd ..
deployer@30bf6f140697:/ $ ls
app  bin  boot  dev  etc  flag.txt  home
deployer@30bf6f140697:/ $ cat flag.txt
THM{DOCKER_ESCAPE_SUCCESS}
deployer@30bf6f140697:/ $
deployer@30bf6f140697:/ $
```

Bonus Question: There is a secret code contained within the news site running on port 5002 ; this code also happens to be the password for the deployer user! They should definitely change their password. Can you find it?

Respuesta: DeployMaster2025!



Liked the content? We have plenty more where this came from! Try our [Container Vulnerabilities](#) room.

Check